Information Security Policy

COOKIE-BANNER.CA Version: 1.0 **Effective Date:** March 28, 2026 **Next Review Date:** March 28, 2027 **Contact:** security@cookie-banner.ca

---

1. Purpose

This policy establishes the information security principles, standards, and responsibilities for COOKIE-BANNER.CA, a cookie consent management platform (CMP). It applies to all systems, data, and services operated by the organization.

COOKIE-BANNER.CA is a solo-founder, fully remote SaaS company with no physical office or self-managed data center. Our security posture relies on carefully selected infrastructure providers, strong access controls, and disciplined operational practices rather than on-premises security measures.

2. Scope

This policy covers:

- All production systems and environments (application, database, payment processing)
- All customer data, including consent records and account information
- All third-party services integrated into the platform
- The founder and any future contractors or employees with access to company systems

3. Roles and Responsibilities

Role	Responsibility
Founder / Security Lead	Owns this policy. Responsible for all security decisions, access management, incident response, and vendor assessments.
Future Contractors	Must agree to this policy before accessing any company system. Access is granted on a least-privilege basis and revoked upon contract end.

As a solo-founder organization, the founder currently holds all security responsibilities. If the team grows, a formal delegation of duties will be documented.

4. Data Classification

All data handled by COOKIE-BANNER.CA is classified into one of the following categories:

Classification	Description	Examples	Handling
Confidential	Data whose exposure would cause significant harm to the business or customers.	API keys, database credentials, Stripe secrets, authentication tokens, session secrets	Stored only in encrypted environment variables managed by Vercel. Never committed to source control.
Restricted	Personal data or customer data subject to privacy regulations.	Email addresses, consent records, account details, billing metadata	Encrypted at rest and in transit. Access limited to production systems. Processed in accordance with GDPR, PIPEDA, Law 25, and PECR.

Classification	Description	Examples	Handling
Internal	Business data not intended for public disclosure.	Application source code, internal documentation, analytics, operational logs	Stored in private repositories and internal tools. Access controlled via SSO or strong authentication.
Public	Information intentionally made available.	Marketing website content, published documentation, blog posts	No access restrictions.

5. Access Control

Principles

- **Least Privilege:** Every account and service is granted the minimum permissions required to perform its function.
- **No Shared Accounts:** Each person and service uses a unique identity.
- **MFA Required:** Multi-factor authentication is enabled on all critical accounts, including Vercel, Supabase, Stripe, GitHub, and DNS providers.

Authentication Standards

- All administrative access requires MFA (TOTP or hardware key).
- NextAuth.js manages customer authentication with secure, httpOnly session cookies.
- API keys are scoped to the minimum permissions necessary.
- Service-to-service communication uses environment-injected secrets, never hardcoded credentials.

Access Reviews

Access to all systems is reviewed quarterly. Unused accounts and stale API keys are revoked promptly.

6. Encryption Standards

Data in Transit

- All traffic is encrypted via TLS 1.2 or higher.
- HSTS is enforced on all domains.
- Vercel provides automatic TLS certificate provisioning and renewal.

Data at Rest

- Supabase (PostgreSQL) encrypts all data at rest using AES-256.
- Vercel environment variables are encrypted at rest.
- Stripe handles all payment card data; no card numbers are stored or processed by COOKIE-BANNER.CA systems.

Secrets Management

- Secrets are stored exclusively in Vercel environment variables and Supabase vault.
- Secrets are never committed to version control. The `.gitignore` file excludes `.env*` files.
- Secrets are rotated at least annually, or immediately upon suspected compromise.

7. Infrastructure and Third-Party Risk Management

COOKIE-BANNER.CA does not operate its own servers or data centers. All infrastructure is provided by third-party vendors selected for their security certifications and practices.

Provider	Function	Security Certification
Vercel	Application hosting, edge network, CI/CD	SOC 2 Type II
Supabase	PostgreSQL database, authentication services	SOC 2 Type II
Stripe	Payment processing	PCI DSS Level 1
GitHub	Source code management, CI/CD	SOC 2 Type II

Vendor Assessment

- Vendor security certifications are verified before adoption and reviewed annually.
- Only vendors with established security programs and publicly available compliance documentation are selected.
- Data processing agreements (DPAs) are executed with vendors that process personal data.

Dependency Management

- Application dependencies are monitored for known vulnerabilities via GitHub Dependabot.
- Critical security patches are applied within 72 hours of disclosure.

8. Incident Response

In the event of a suspected security incident:

1. **Contain** – Immediately revoke compromised credentials and isolate affected systems.
2. **Assess** – Determine the scope and severity of the incident.
3. **Notify** – Inform affected customers and relevant supervisory authorities within the timelines required by applicable law (72 hours under GDPR, as soon as feasible under PIPEDA/Law 25).
4. **Remediate** – Fix the root cause and restore normal operations.
5. **Document** – Record the incident, timeline, impact, and corrective actions taken.

Security incidents can be reported to security@cookie-banner.ca.

9. Secure Development Practices

- All code changes go through pull request review before merging to production.
- Environment variables are used for all configuration and secrets; nothing is hardcoded.
- Input validation is performed on all API endpoints using Zod schema validation.
- Dependencies are kept up to date and audited for known vulnerabilities.
- Production deployments are managed through Vercel's CI/CD pipeline with automatic preview environments.

10. Business Continuity

- **Database Backups:** Supabase performs automated daily backups with point-in-time recovery.
- **Source Code:** All code is stored in a private GitHub repository with full version history.
- **Service Availability:** Vercel's edge network provides global redundancy and automatic failover.
- **Disaster Recovery:** In the event of a provider outage, the application can be redeployed to an alternative provider using the source code and database backups.

11. Security Awareness

- The founder maintains current knowledge of security best practices, privacy regulations, and emerging threats relevant to web application security and consent management.
- If the team grows, all personnel with access to company systems will complete security awareness orientation before gaining access, with annual refreshers thereafter.

12. Regulatory Compliance

COOKIE-BANNER.CA processes personal data in compliance with:

- **GDPR** (EU General Data Protection Regulation)
- **PIPEDA** (Canada's Personal Information Protection and Electronic Documents Act)
- **Law 25** (Quebec's Act respecting the protection of personal information in the private sector)
- **PECR** (UK Privacy and Electronic Communications Regulations)

Data subject access requests, deletion requests, and consent withdrawal requests are honored within the timelines required by each applicable regulation.

13. Policy Review

This policy is reviewed and updated:

- **Annually**, on or before the anniversary of the effective date.
- **Upon significant change**, such as a new infrastructure provider, a material change in data processing, or a security incident.
- **Upon regulatory change**, when new laws or amendments affect the company's obligations.

All revisions are documented with a version number and effective date.

Version	Date	Author	Summary
1.0	2026-03-28	Founder	Initial policy